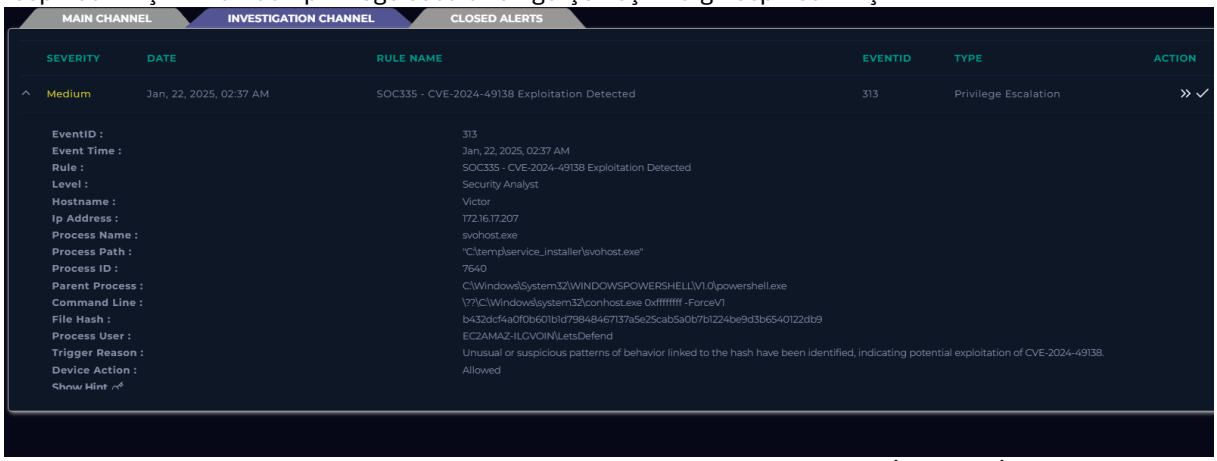
Alarm Bilgileri

Alarm adı:
SOC335 – CVE-2024-49138 Exploitation Detected

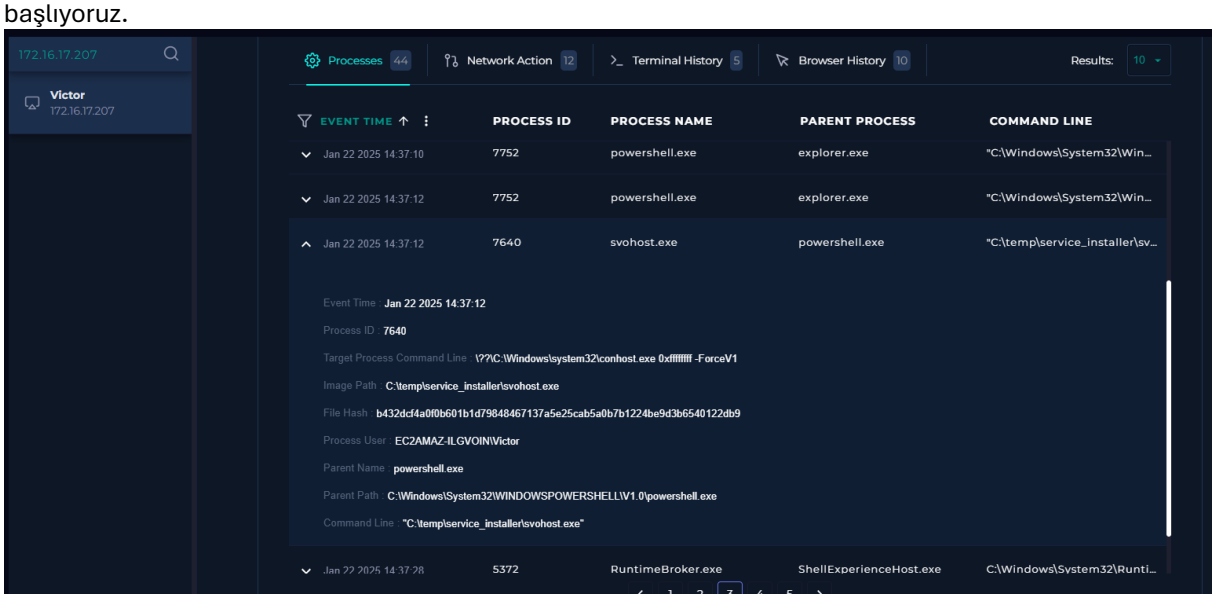
Tarih ve Saat:
22 Ocak, 2025 – 02:37 ÖÖ

Hedef Makine (Hostname / IP):
Victor - 172.16.17.207

Olay Analizi (Investigation):
İncelemeler sonucunda, hedef sistem üzerinde Powershell ile zararlı bir dosyanın indirilip çalıştırıldığı tespit edilmiştir. Ardından privilege escalation gerçekleştirildiği tespit edilmiştir.



Sahiplendiğimiz uyarı. Kritik bilgiler: Olay ID, Olay Zamanı, Host Adı, IP Adresi, İşlem ID, İşlem Dizini.
Bu bilgilere dayanarak elimizdeki IP Adresi ve Hostname ile o makinede yapılmış işlemleri incelemeye başlıyoruz.



Görüldüğü gibi saldırgan zararlı yazılımını bir Windows servisi olarak göstermeye çalışmış. Dosya adın svohost.exe. Sadece 1 harf değiştirmiş. Burada zararlı yazılımını powershell aracılığı ile indirdiğini görüyoruz.

Burada saldırgan çalıştırdığı zararlı yazılım ile yetki yükseltme yaptığını görüyoruz. Kullanıcı SYSTEM yetkisi ile powershell açabilmiş.

Burada ise saldırganın SYSTEM yetkisi alıp almadığını kontrol ettiğini görüyoruz çünkü whoami komutunu çalıştırmış.

Tarih ve zamana baktığımız zaman tahminimce saldırgan bu 2 IP adresinden biri diyebilirim.

C:\temp\service_installer\svohost.exe = Saldırgan burada zararlı yazılımını çalıştırmayı denemiştir.

\??\C:\Windows\system32\conhost.exe 0xffffffff -ForceV1 = Saldırgan burada çalıştırdığı zararlı yazılımın komut satırı ortamında düzgün çalışabilmesi için Windows Console Host başlatmıştır. Bu işlem, zararlı komutların arka planda çalıştırılmasını sağlar.

C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe = Saldırgan alarm alınan exploit'i kullanarak yetki yükseltme yaptıktan sonra, elde ettiği SYSTEM yetkisi ile komut çalıştırabilmek için yeni bir powershell açmıştır.

C:\Windows\System32\whoami.exe = Saldırgan yaptığı yetki yükseltmenin gerçekten de çalışıp çalışmadığını kontrol etmiştir.

Sonuç ve Aksiyon (Verdict):

Durum:

True Positive

Svohost.exe adındaki dosya, svchost.exe sürecini taklit etmektedir. Buna masquerading diyebiliriz.
Dosya standart sistem dizini yerine **temp** altında çalıştırılmış.
Süreç powershell ile başlatılmıştır. Bu direkt şüpheli bir işlemdir.
SYSTEM yetkisi elde edilmiştir.

Windows Common Log File System Driver Elevation of Privilege Vulnerability **CVE-2024-49138** başarı ile çalıştırılmıştır. NVD - CVE-2024-49138

Containment:

Lateral movement ve diğer sorun açabilecek işlemlerin yapılmaması için makine ağdan izole edilmiştir.